Matriz de Riesgos Técnicos del Pipeline CI/CD

Proyecto: CI/CD Cloud Económico para Aplicaciones Web con GitHub Actions y Vercel | Grupo 3 | Fase 2: Implementación y despliegue del pipeline

Repositorio: MelJuarezCloud/cicd-cloud-app | Responsable del documento: Zuleima Beatriz Medina Morales | Actualizado: 02/11/2026

Equipo: Melvin Omar Juárez Rodríguez (Líder y Co-DevOps), Carlos Armando Martínez Chicas (Ingeniero Cloud), Tamara Abigail Martínez Lemus (QA) y Zuleima Beatriz Medina Morales (Riesgos y Documentación).

1. Alcance

Esta matriz identifica los riesgos técnicos del pipeline real del proyecto: un workflow en GitHub Actions (.github/workflows/main.yml) con los jobs lint, test (matrix Node 22 y 24), build, deploy-dev y deploy-prod, que publica una aplicación Node.js en Vercel (plan gratuito). Los riesgos marcados como ocurridos se basan en incidentes registrados durante la Fase 2.

No aplican a este proyecto los riesgos de publicación de imágenes o artefactos en un registro ni los de migración de base de datos, porque la aplicación no usa contenedores ni base de datos.

2. Cuadro de riesgos técnicos

ID	Riesgo técnico	Prob.	Impacto	Estrategia de recuperación	Estrategia de rollback	Responsable	Estado
R01	Falla en el build o compilación	Media	Alto	Revisar el log del job Build en GitHub Actions, verificar dependencias con npm ci y reproducir el error en local.	Revertir el commit o el PR defectuoso en dev y volver a la última versión con checks en verde.	Melvin	Controlado: el job Build depende de lint y test (PR #2)
R02	Secretos mal configurados, ausentes o expuestos (VERCEL_TOKEN, VERCEL_ORG_ID, VERCEL_PROJECT_ID)	Media	Alto	Validar nombres y disponibilidad en Settings > Secrets and variables > Actions sin imprimir valores en los logs.	Detener el despliegue; si hubo exposición, revocar el token en Vercel, generar uno nuevo y actualizar el secreto.	Carlos	Controlado: secretos solo en GitHub Secrets. Pendiente: búsqueda de valores en el repositorio
R03	Job colgado o sin límite de tiempo (timeout) en GitHub Actions	Alta	Alto	Cancelar el run, identificar el job bloqueado y agregar timeout-minutes a los jobs de deploy.	Cancelar el workflow y volver a ejecutarlo una sola vez cuando la causa esté resuelta.	Melvin	Ocurrió, en curso: aún no se configura timeout-minutes
R04	Fallo en pruebas automatizadas o pérdida de cobertura	Media	Alto	Analizar el log del job Test (Node 22 y 24), reproducir el error y corregir el código o la prueba.	Revertir el cambio que causó la regresión; el deploy queda bloqueado porque depende de test.	Tamara	Controlado: 13 pruebas en 5 archivos y 100% de cobertura en sum.js (PR #6 y #7)
R05	Dependencias vulnerables o incompatibles (npm audit: 27, 4 bajas y 23 moderadas)	Alta	Medio	Revisar con npm audit sin usar --force, actualizar de forma controlada y probar en una rama feature.	Restaurar el package-lock.json anterior (commit c242469) y las versiones previamente aprobadas.	Melvin y Zuleima	Pendiente: revisión controlada
R06	Error en variables de entorno del hosting (Vercel Preview y Production)	Media	Alto	Comparar las variables del dashboard con .env.example y verificar que existan en Preview y Production.	Restaurar la configuración anterior y volver a desplegar la última versión estable.	Carlos	Pendiente: captura del dashboard

ID	Riesgo técnico	Prob.	Impacto	Estrategia de recuperación	Estrategia de rollback	Responsable	Estado
R07	Despliegue colgado o fallido en Vercel (Building por más de 12 minutos en tres intentos)	Alta	Alto	Cancelar el run, cancelar desde el dashboard de Vercel los despliegues en Building o Queued, y hacer un solo re-run.	No promover a main; mantener en producción la última versión en estado Ready.	Carlos	Ocurrió, en curso: pendiente de respuesta de Carlos
R08	Permisos insuficientes o excesivos del token o del workflow	Baja	Alto	Revisar el alcance del token de Vercel y los permisos declarados en el workflow.	Revocar y regenerar el token; mantener permissions: contents: read en main.yml.	Carlos	Controlado: permissions: contents: read y secretos solo en jobs de deploy
R09	Falta de package-lock.json o caché de npm inconsistente	Media	Medio	Generar y versionar el lockfile, usar npm ci y cache: npm en setup-node; invalidar la caché si es necesario.	Restaurar el commit c242469 que incorporó el lockfile.	Melvin	Ocurrió y se resolvió: commit c242469 (PR #2)
R10	Cambios directos al workflow sin Pull Request (se perdieron --coverage y los reintentos de deploy)	Media	Medio	Restaurar main.yml mediante PR con revisión; recordar el flujo feature/* hacia dev.	Revertir los commits directos o restaurar la versión del PR #7.	Melvin	Ocurrió y se resolvió: PR #7. Pendiente: protección de ramas
R11	URL de preview protegida por login de Vercel (Deployment Protection)	Alta	Medio	Desactivar Vercel Authentication en Settings > Deployment Protection o invitar a los evaluadores al equipo.	No aplica: es un ajuste de configuración reversible.	Carlos	Ocurrió, en curso: pendiente de respuesta de Carlos
R12	Consumo del plan gratuito (2.000 minutos de GitHub Actions y límites de Vercel)	Media	Alto	Cancelar runs colgados, usar concurrency con cancel-in-progress, timeout-minutes y paths-ignore para docs/.	Desactivar temporalmente el deploy automático y desplegar solo desde main.	Melvin	Parcial: concurrency activo; falta timeout y paths-ignore
R13	Acciones y runners desactualizados (aviso de Node 20 y migración de ubuntu-latest a Ubuntu 26)	Media	Bajo	Subir las versiones de checkout y setup-node tras probar en un PR; fijar ubuntu-24.04 si hay fallos.	Volver a las versiones anteriores de las acciones en main.yml.	Melvin	Pendiente: solo advertencias, sin fallos
R14	Ramas dev y main desalineadas (115 commits de diferencia y conflictos al unirlas)	Alta	Alto	Crear el PR dev hacia main, resolver conflictos conservando las versiones de dev y verificar los checks.	Cancelar el PR si hay conflictos sin resolver; main conserva su estado actual.	Melvin	Ocurrió, en curso: aún sin primer despliegue a producción
R15	Indisponibilidad o lentitud de servicios externos (GitHub, Vercel, registro de npm)	Media	Alto	Reintentar con límite (el deploy tiene 3 intentos), revisar el estado de los proveedores y esperar.	Cancelar el despliegue y mantener la versión estable en producción.	Carlos	Parcial: los reintentos no cubren procesos colgados (ver R03)

Escala: probabilidad baja, media o alta, según los incidentes ocurridos en la Fase 2; impacto bajo, medio, alto o crítico, según la afectación al despliegue, la seguridad y la operación. Verde: controlado o resuelto. Naranja: ocurrió y sigue en curso. Amarillo: pendiente o parcial.

3. Protocolo de recuperación y rollback

1. Detectar: identificar el job fallido en la pestaña Actions, registrar el commit, el run y el entorno afectado (Preview o producción).

2. Contener: cancelar el workflow si está colgado, no hacer re-run repetidos (cada intento suma un despliegue a la cola de Vercel) y no promover cambios a main.
3. Recuperar: corregir la causa en una rama feature, abrir un Pull Request hacia dev y esperar los checks en verde.
4. Rollback: revertir el merge defectuoso con un Pull Request de reversión, o desde el dashboard de Vercel volver a promover el último despliegue en estado Ready.
5. Verificar: confirmar el run en verde, abrir la URL desplegada y revisar los logs del despliegue.
6. Documentar: registrar causa raíz, tiempo de recuperación y acción preventiva en la bitácora técnica.

4. Controles preventivos

Control	Implementación en el proyecto	Riesgos que mitiga	Estado
Validación antes del despliegue	Los jobs lint y test deben pasar antes de build y deploy (needs en main.yml).	R01, R04	Implementado
Despliegue separado por rama	Push a dev publica en Preview y push a main publica en producción.	R14	Implementado
Pruebas con cobertura y matrix	npm test con cobertura en Node 22 y 24.	R04	Implementado
Caché y dependencias fijas	cache: npm y npm ci con package-lock.json.	R05, R09	Implementado
Permisos mínimos	permissions: contents: read; secretos solo en los jobs de deploy.	R02, R08	Implementado
Reintentos de deploy	Bucle de 3 intentos con espera de 10 segundos.	R15	Implementado
Cancelación de ejecuciones duplicadas	concurrency con cancel-in-progress.	R12	Implementado
Control de tiempos	Agregar timeout-minutes (por ejemplo 10) a los jobs de deploy.	R03, R07, R12	Pendiente
Protección de ramas	Pull Request obligatorio y checks requeridos en main y dev.	R10	Pendiente
Ignorar cambios de documentación	paths-ignore para docs/ y bitácoras en el trigger de push.	R12	Pendiente
Health check posterior al despliegue	Endpoint /health y verificación tras el deploy.	R07	Pendiente

5. Incidentes registrados en la Fase 2

Fecha	Riesgo	Descripción	Resultado
01/11/2026	R09	Caché de npm fallaba por falta de package-lock.json; se generó con Codespaces.	Resuelto: commit c242469 (PR #2)
01/11/2026	R10	Push a dev desplegaba con --prod; se separaron los jobs de deploy por rama.	Resuelto: PR #2
01/11/2026	R07	La URL desplegada respondía 404 por falta de una página; se agregó public/index.html.	Resuelto: PR #5 (commit 9137dd3)
01/11/2026	R10	Commits directos a dev modificaron main.yml (sin cobertura, con --if-present y sin reintentos).	Resuelto: PR #7

Fecha	Riesgo	Descripción	Resultado
02/11/2026	R07	Deploy Dev colgado en Building más de 12 minutos en tres intentos; run cancelado a los 14 minutos.	En curso: cola de Vercel
02/11/2026	R11	La URL de Preview solicita inicio de sesión en Vercel.	En curso: desactivar Vercel Authentication
02/11/2026	R14	La comparación dev hacia main indica que no se puede unir automáticamente.	En curso: resolver conflictos

6. Criterios de activación del rollback

- El despliegue en producción no abre la URL pública o responde con error.
- Una regresión crítica aparece después de unir a main (pruebas o comportamiento de la página).
- Se detecta exposición de un secreto en el código, los logs o las capturas: revocar y rotar el token de inmediato.
- El servicio no se recupera dentro de los 30 minutos definidos como tiempo máximo de recuperación.

Regla operativa: no se une a main ni se despliega a producción si lint, test o build fallaron.

7. Indicadores de eficacia

Indicador	Objetivo	Situación actual
Ejecuciones del pipeline en verde	95% o más	Medición pendiente al cierre de la Fase 2
Despliegues con pruebas aprobadas	100%	Cumplido: deploy depende de lint, test y build
Secretos expuestos en logs o código	0	Verificación pendiente en el repositorio
Tiempo de recuperación ante un incidente recuperable	30 minutos o menos	Por registrar en la bitácora
Jobs de deploy con timeout configurado	100%	Pendiente (0 de 2)

Los objetivos son referencias del equipo y se ajustarán con los datos del cierre de la Fase 2.

8. Evidencias de respaldo

- PR #2: pipeline con jobs separados, caché, matrix, reintentos y deploy por rama.
- PR #6: pruebas unitarias; PR #7: restauración del workflow con cobertura al 100% en sum.js.
- PR #5: página inicial (public/index.html); PR #8: README del proyecto.
- Run con Deploy Dev cancelado a los 14 minutos (commit a3f8049), y captura de Annotations con los avisos de Node 20 y Ubuntu 26.